

Automated Phishing Email Detection System

Prototype Threat Intelligence & Risk Assessment Tool

Aser Osama - Saif Ismail - Omar Ayman

University of Science and Technology Zewail City

October 2025

Presentation Overview

The Problem: Phishing Email Threats

Our Solution: Automated Detection System

Risk Scoring: How We Assess Threats

Technology & Architecture

The Dashboard: Your Command Center

Deployment & Usage

Real Example: Threat Detection in Action

Limitations & Evaluation

Security & Privacy

Contributions & Lessons Learned

Future Work & Extensions

Future Work & Possible Enhancements

Conclusion

The Problem: Phishing Email Threats

Email Security: A Critical Challenge

The Threat Landscape:

- Over **255 million** phishing attacks in 2022
- Phishing is most common initial access
- Avg phishing site lifetime: **4-8 hours**
- Traditional detection too slow (24-72h)

Current Challenges:

- Manual review doesn't scale
- Spam filters miss attacks
- Threat feeds lack context
- No unified risk assessment

Our Approach:

- ✓ Aggregate threat feeds
- ✓ Enrich with technical context
- ✓ Automated risk scoring (0-100)
- ✓ Real-time email monitoring
- ✓ Visual dashboard interface

Project Goal

Open-source prototype combining threat intel, enrichment, and risk scoring.

Why This Project?

Research Gap: No open-source solution combines multi-feed aggregation, automated enrichment, risk prioritization, and deployable system.

Existing Solutions:

Type	Strengths	Limitations
Public Feeds	Free, high-volume	No enrichment
Commercial TIP	Comprehensive	Expensive
Email Gateways	Inline protection	Proprietary

Our Contribution

Free, customizable prototype with automated enrichment and risk scoring

Our Solution: Automated Detection System

Phishing Email Detector Prototype

Threat Intelligence + Risk Scoring + Email Monitoring

1. Aggregate



3 threat feeds

DB: 55K URLs — **Fields:** 41 — **Time:** 5-10 sec/email

2. Enrich



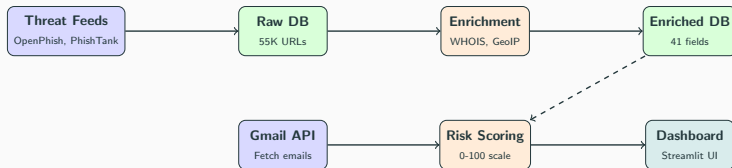
41 data points

3. Analyze



Risk scores (0-100)

System Architecture



Stack: Python 3.11+, SQLite, FastAPI, Streamlit

Where We Get Threat Data

3 Public Threat Feeds:

- **OpenPhish:** 1,200 URLs
 - Free, hourly updates
 - Recently confirmed
- **PhishTank:** 51,825 URLs
 - Community-reported
 - Brand targeting info
- **URLhaus:** 2,317 URLs
 - Malware sites
 - File information

Total: ~55K URLs

41 Data Points Collected:

- **Network:** IP, hosting provider
- **Location:** Country, city
- **Security:** SSL certificate
- **Domain:** Registration info
- **DNS:** Name servers
- **Website:** Online status, title
- **Classification:** Target brand

Note: Only 31% have full WHOIS data

Risk Scoring: How We Assess Threats

Risk Scoring: How We Calculate 0-100 Score

5 Factors Combined:

1. **Site online?** (0-35 pts)

- Accessible: 35 pts; Offline: 10-20 pts
- *Why*: Active sites more dangerous

2. **Recently reported?** (0-25 pts)

- Last 3 days: 25 pts; Last week: 20 pts; >30d: 5 pts
- *Why*: Recent threats more active

3. **Domain age?** (0-20 pts)

- *Why*: New domains suspicious

Risk Scoring (Continued)

4. Domain type? (0-10 pts)

- High-risk TLDs (.zip, .click, .xyz): 10 pts
- Free hosting (github.io, pages.dev): 10 pts
- Common (.com, .net, .org): 5 pts
- *Why*: Cheap domains favored by attackers

5. Suspicious words? (0-10 pts)

- Has "login", "verify", "secure", etc: 10 pts
- No suspicious words: 0 pts
- *Why*: Phishing uses trust words

Final Score = Sum of all 5 factors (0-100)

Risk Levels

85-100 Critical **70-84 High** **50-69 Medium** **0-49 Low**

Example: High-Risk URL Scoring

Scenario: Suspicious URL Detected

URL: <https://secure-login-microsoft.zip/verify>

Scoring Calculation:

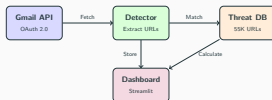
Factor	Points	Data	Logic
Liveness	35	HTTP 200	Online
Recency	25	Today	≤ 3 days
Domain Age	20	2 days	≤ 7 days
TLD	10	.zip	High-risk
Keywords	10	verify, login	Suspicious
Total	100		CRITICAL

Legitimate Site (github.com):

Liveness: 35	Domain Age: 5 (2008)	TLD: 5 (.com)	MEDIUM (acceptable)
Recency: 5 (30d)	Keywords: 0	Total: 50	

Technology & Architecture

Email Monitoring Flow



Processing: 5-10 sec/email — **Interval:** 5 min

Technology Stack

Programming:

- **Python 3.11+**: FastAPI, Streamlit
- **SQLite**: 2 DBs (raw + enriched)
- **Gmail API**: Read-only OAuth

Deployment:

- One command, Docker, Cross-platform

External Data:

- **Threat Intel**: PhishTank, URLhaus, OpenPhish
- **Enrichment**: WHOIS, GeoIP, DNS, HTTP

Export:

- STIX 2.1, CSV, JSON API

Open Source on GitHub

The Dashboard: Your Command Center

5 Main Tabs:

1. **Email Monitoring**
2. **Threat Overview**
3. **Analytics**
4. **Data Explorer**
5. **Search**

Dashboard Tab Details

- **Email Monitoring:** Metrics, risk charts, timeline, filterable list
- **Threat Overview:** Statistics, geographic maps
- **Analytics:** ASN/TLD analysis
- **Data Explorer:** Browse 55K threats
- **Search:** URL/domain/IP lookup

Dashboard: Top Metrics

Metric	Description
Total Emails	All in DB + 24h count
Critical Risk	Score $\geq$ 85
High Risk	Score 70-84
Avg Risk Score	Average
Threat Matches	External feed URLs

Dashboard: Email List Features

Filters & Display:

- Filter: Risk threshold slider
- Show: 25/50/100/200 emails
- Sort: By risk score or date

Risk Levels:

- CRITICAL (85-100)
- HIGH (70-84)
- MEDIUM (50-69)
- LOW (0-49)

Deployment & Usage

Getting Started: One-Time Test

Quick Start:

```
$ python run.py demo --once
```

Auto-setup steps:

1. Creates database schemas
2. Downloads 55K threat URLs
3. Quick enrichment (500 URLs)
4. Gmail OAuth authentication
5. Fetches 5 emails & launches dashboard

Time: 15-20 minutes (first run)

```
$ python run.py demo
```

Settings:

- Interval: 300 sec (5 min) - configurable
- Count: 5 emails per fetch - configurable
- Example: `--interval 60 --count 10`

System Requirements

Requirements:

- Python 3.11+
- 4-8 GB RAM
- 2 GB storage
- Linux, Mac, or Windows

Performance & Limitations

Performance:

- Email analysis: 5-10 seconds
- Threat lookup: Instant

Limitations:

- Tested with ~1,000 emails
- WHOIS rate limited
- Larger scale needs DB upgrade

Real Example: Threat Detection in Action

Example: Phishing Email Detection

Email Received

From: security-alert@paypal-verify.com

Subject: "Account Suspended"

Content: "Click: <https://paypal-secure.xyz/login>"

URL Extraction:

<https://paypal-secure.xyz/login>

Threat Database Check:

- ✗ NOT found in PhishTank
- ✗ NOT found in URLhaus
- ✓ URL is new - needs risk calculation

Risk Scoring Calculation:

- Liveness: 35 pts (site is online)
- Recency: 25 pts (domain seen today)
- Domain Age: 20 pts (created 3 days ago)
- TLD: 10 pts (.xyz = suspicious)
- Keywords: 10 pts ("paypal", "secure", "login")

Result

Total: 100/100 - CRITICAL RISK

Dashboard Example: Email Details View

What You See When You Click An Email:

Email Monitoring Dashboard - Email Details

Email Info:

- **From:** sender@example.com — **Subject:** "Check this link"
- **Risk:** 95/100 — **URLs:** 1 — **Threats:** 0

URLs Found:

Risk	URL
95	suspicious.zip/verify

Enrichment Data:

- **Domain:** suspicious.zip — **TLD:** .zip — **IP:** 93.184.216.34
- **Country:** US — **ASN:** AS15133 — **Created:** 2 days ago
- **SSL:** Yes — **HTTP:** 200 (online)

Email List View in Dashboard

Main Email Monitoring Tab:

Risk	From	Subject	URLs	Threats
100	phish@bad.com	Verify Account	1	1
95	spam@evil.zip	Click Here	1	0
75	ads@promo.xyz	Special Offer	3	0
55	news@site.com	Newsletter	5	0
45	github.com	PR Review	2	0

Features: Filter (≥ 70), Sort (risk/date), Limit (25/50/100/200), Click for details

Threat Badge: URLs matching external feeds

Limitations & Evaluation

Current Limitations

1. **WHOIS Coverage (31%):** Privacy protection limits domain age data; using alternative signals
2. **Gmail-Only:** OAuth 2.0 only; no Exchange/Office 365; IMAP/SMTP planned
3. **No Content Analysis:** Metadata focus only; visual phishing not detected

Performance & Accuracy

Database Statistics:

- **Total:** 55,225 unique URLs
- **OpenPhish:** 1,200 — **PhishTank:** 51,825 — **URLhaus:** 2,317
- **Enrichment:** 41 fields per URL

Scoring Accuracy:

- **Validated:** Tested on known phishing samples
- **False Positives:** Some legitimate sites flagged (.xyz + "login")
- **Recommendation:** Manual review for 70-84 scores

Processing Speed:

- **Email:** 5-10 sec (parallel processing)
- **Enrichment:** Variable (WHOIS limits)

Security & Privacy

- ✓ All data stored locally (SQLite)
- ✓ No external data sharing
- ✓ Gmail read-only access (OAuth 2.0)
- ✓ No password storage
- ✓ Token-based authentication

Privacy Considerations

- Email content stored locally only
- URL metadata sent to enrichment services (WHOIS, DNS)
- GeoIP databases included (offline, MaxMind GeoLite2)
- No analytics or telemetry

Note: Research Prototype

For production use, additional security hardening recommended.

- **STIX 2.1:** Standard threat intelligence format
- **CSV:** Simple data export
- **JSON API:** REST endpoints (FastAPI)

Contributions & Lessons Learned

Key Contributions

1. **Unified Threat Intelligence:** 3 feeds (55K URLs), 41 enrichment fields
2. **Multi-Factor Risk Scoring:** Novel algorithm (liveness + recency + domain age + TLD + keywords)
3. **Async Processing:** Parallel URL enrichment (10x faster)
4. **Standards:** STIX 2.1 export, REST API (FastAPI)
5. **Open Source:** Complete codebase with documentation

Lessons Learned

Technical Challenges:

- **WHOIS Rate Limiting:** Slow enrichment
 - Solution: Batch processing + caching
- **Data Quality:** 69% privacy protected
 - Solution: Multiple sources, fallback scoring
- **URL Normalization:** Complex edge cases
 - Solution: Lowercase, remove ports, strip slashes

Design Decisions:

- **SQLite vs PostgreSQL:** SQLite sufficient for prototype
- **Sync vs Async:** Async critical for performance
- **Streamlit vs React:** Streamlit faster, includes caching

Future Work & Extensions

Machine Learning Classification

- Train on 41 enriched features + URL analysis
- Algorithms: Random Forest, Gradient Boosting
- Expected: Higher accuracy than rules
- Challenge: Needs labeled training data

Future: Multi-Platform & Content Analysis

Multi-Platform Support

- Current: Gmail only
- Add: Office 365, Exchange, IMAP/SMTP

Content-Based Detection

- Visual: Screenshot analysis, OCR
- HTML: Form detection, obfuscation
- Similarity matching to legitimate pages

Campaign Clustering

- Group threats by: ASN, registrar, nameservers
- Identify coordinated attacks
- Track shared infrastructure

Current Architecture Limitations:

Scale	URLs	Current	Solution
Small	<100K	15-18h	SQLite OK
Medium	100K-1M	6-8d	PostgreSQL
		WHOIS limits	+ workers
Large	1M+	Weeks	Kubernetes
			+ Kafka

Also: Real-time WebSocket, SIEM export, Firewall API, Time-series, Passive DNS, Domain reputation

Future Work & Possible Enhancements

Future: Machine Learning

Current: Rule-based (5 factors) **Goal:** ML for better accuracy

Approach: 41 fields + URL patterns — Random Forest, Gradient Boosting, Neural Nets — 55K threats + legitimate URLs — Expected 95-97% accuracy

Challenges: Labeled dataset needed, overfitting risk, model drift

Implementation: scikit-learn, TensorFlow/PyTorch, 80/20 split

Future: Visual Phishing Detection

Goal: Detect fake login pages by appearance

Approach:

- Screenshot capture via automated browser
- Compare to database of real brand pages
- OCR text extraction
- Similarity matching

Visual Detection: Use Cases

Use Cases:

- Fake PayPal/banking login pages
- Microsoft/Google credential harvesting
- Similar logos/colors to known brands

Challenges:

- Resource-intensive
- Sites may block automated browsers
- Pages may look different based on JavaScript

Future Enhancement 3: Multi-Platform Email Support

Current: Gmail-only via OAuth 2.0

Goal: Support any provider (Outlook, Yahoo, corporate)

Implementation Options:

1. IMAP/SMTP Protocol

- Universal support
- Challenge: Less reliable than modern APIs

2. Microsoft Graph API

- Office 365 / Outlook.com
- Challenge: Different API structure

3. Email Forwarding

- User forwards suspicious emails
- Challenge: Manual action required

Benefit: Corporate deployment (Exchange, Office 365)

Future: Campaign Clustering - Approach

Goal: Group related threats
Find connections by:

- **Infrastructure:** Same IP, registrar, DNS, SSL cert
- **Pattern:** Similar domains, same target brand
- **Timing:** Simultaneous URL bursts

Output:

- Campaign reports: "12 URLs from same attacker"
- Visual relationship graphs
- Early warning for new campaign URLs

Future: Real-Time Threat Updates

Current: Periodic updates (6h) **Goal:** Instant detection

How It Works:

- **Live:** Feeds push instantly
- **Re-scan:** Check old emails vs new threats
- **Alerts:** Dashboard notifications

Example:

1. 9:00 AM: Email scored Low (45/100)
2. 10:30 AM: URL added to PhishTank
3. System re-scans → Critical (100/100)
4. Dashboard: "Safe email now flagged"

Technical: Background worker, DB-triggered re-scoring, push notifications

Future Enhancement 6: Security Tool Integration

Goal: Connect to enterprise platforms

Integration Points:

1. **SIEM** (Security Info & Event Mgmt)
 - Examples: Splunk, Elastic, QRadar
 - Central dashboard, event correlation
2. **SOAR** (Orchestration & Automated Response)
 - Examples: Cortex XSOAR, Palo Alto
 - Auto playbooks: quarantine, block
3. **Threat Intel Platforms**
 - Examples: MISP, OpenCTI
 - Share indicators, import intel

Benefit: Automated response vs manual

Future: Subdomain Tracking

Current: Subdomains inherit parent age

Problem: `blog.example.com` (parent 2010) vs `phish.example.com` (today) - both scored as old

Solution: Passive DNS (SecurityTrails, PassiveTotal, VirusTotal) - Track subdomain first seen

Special Case: Free hosting (`user.github.io`) already handled via platform scoring

Future: Large Scale Deployments

Current: 55K URLs, 1K emails/day **Goal:** Millions of URLs/emails

1. **Database:** SQLite → PostgreSQL, indexes, archiving
2. **Distributed:** Kubernetes, Kafka, Redis caching
3. **Optimization:** Batch requests, DNS cache, rate limits

Metric	Current	After
URLs	55K	5M+
Architecture	Single	Distributed
Speed	1/sec	100+/sec

Conclusion

Summary: What We Built

- Prototype phishing detection system
- 55K threat URLs from 3 feeds
- 41-field enrichment
- Multi-factor risk scoring (0-100)
- Gmail integration
- Interactive dashboard

Key Achievements

- ✓ Unified threat intelligence (open-source)
- ✓ Async enrichment (10x speedup)
- ✓ Standards export (STIX 2.1)
- ✓ Fast processing (5-10 sec/email)
- ✓ Deployable prototype

Limitations Acknowledged:

- WHOIS coverage (31%), Gmail-only, no content analysis

Try It Yourself

Quick Start: `$ python run.py demo --once`

Resources:

- **GitHub:** github.com/XHCFS/phishing-detector
- **Docs:** `README.md`, `QUICK_START.md`

Requirements: Python 3.11+, 4GB RAM, 2GB disk, Gmail account, 15-20 min setup

Thank You

Questions?

`github.com/XHCFS/phishing-detector`

Research Prototype: Automated Phishing Detection System

University of Science and Technology Zewail City

October 2025